



CYBER ATTACK INCIDENT REPORT
(FINAL REPORT)

OCTOBER 2019

TABLE OF CONTENTS

1	INTRODUCTION	3
2	INCIDENT DETAILS	3
3	CAUSE OF INCIDENT	3
4	PHOBOS (BANJO) WHAT DOES IT DO?	4
4.1.1	<i>Description</i>	4
4.1.2	<i>Where did this come from?</i>	4
5	SAUTECH INITIAL ACTIONS	5
6	FLOW OF RECOVERY	6
6.1.1	<i>Servers / Virtual Servers</i>	6
6.1.2	<i>Email Services</i>	6
6.1.3	<i>Shared File Services</i>	6
7	CHANGES TO THE ENVIRONMENT	7
8	FOLLOW UP/ONGOING ACTIONS	7
9	PREVENTION / TRAINING	8
10	CONCLUSION	9
11	THANK YOU	9

1 INTRODUCTION

This document provides the final report on the Cyber / Ransomware attack Sautech (Pty) Ltd experienced 22 September 2019.

2 INCIDENT DETAILS

Sautech (Pty) Ltd was attacked by Cyber / Ransomware on the 22 September 2019. This affected our Primary Data Centre (Hetzner) as well as our Disaster Recovery (DR) Data Centre (IS) (which is off-site), including all Servers, Virtual Machines (VM's), and Network-attached Storages (NAS's). For certain clients, the roles of the Data Centre's mentioned above, are reversed.

This was a planned and highly sophisticated brute force attack, and occurred despite all the precautions, security measurements / policies, preventative maintenance and restrictions Sautech (Pty) Ltd had in place, such as and not limited to Firewalls, Anti-Virus Software, Back up's, Replications etc.

All Primary Data and Back Up's (including email services) hosted by Sautech (Pty) Ltd were either encrypted or deleted.

3 CAUSE OF INCIDENT

The origin of this attack is part of the Dharma Family Ransomware, which primarily targets businesses and uses several methods of distribution. This particular variant is called Phobos (Banjo).

After a successful attack, a ransom demand is made (in Bitcoin) in exchange for decryption keys.

All valuable data is encrypted with AES 256 encryption. The motivation behind the Dharma group is financial gain.

The attack, deletes data, encrypt files, destroys backups, breaks network LUNs, removes log files etc. with most of our data stored on Synology devices.

4 PHOBOS (BANJO) WHAT DOES IT DO?

4.1.1 Description

Phobos is a ransomware-type malicious program that (like most programs of this type) encrypts data / locks files stored and keeps them in this state until a ransom is paid. Phobos renames all encrypted files by adding the **".phobos"** extension plus the victim's unique ID and an email address.

Ransomware developers store these keys on remote servers controlled only by them. Decryption without involvement of cyber criminals is generally impossible, however, we recommended that you never trust these people or contact them - they ignore victims once ransom payments are made. If your computer is infected with Phobos, the best solution is to use an existing data backup and restore files from there. There is no tool currently capable of free file decryption.

The banjo files are a new version of the Phobos ransomware family which is being spread across the Internet to victims worldwide. It is very possible that the same hacking group is behind it or that another collective is responsible for the campaigns. At the same time, several distribution techniques can be used at once in order to affect as many people as possible. This include the sending of **phishing email messages** and the creation of **fake sites** that impersonate well-known companies and services. The posted contents offered within them will lead to the .banjo files virus infection. To make them appear as legitimate-looking they will be hosted on addresses that sound very much like well-known portals and sites.

The virus installation code can be embedded in various **file carriers** which will lead to the infection as soon as they are executed. A popular type is the creation of **macro-infected documents** - they can take all popular file formats: spreadsheets, presentations, databases and text files. They will request that the scripts inside them are run in order to correctly view the contents. The other alternative is to create **malware bundle installers** of popular software. The hackers do this by taking the original installers from their legitimate sources and modifying them in order to include the relevant code.

All of the Banjo virus data can also be uploaded to **file-sharing networks** like BitTorrent where such data are commonly found. The virus code can also be placed inside malicious versions of **web browser plugins**. They are often uploaded to the repositories of the browsers with fake user reviews, developers' credentials and an elaborate description aiming to manipulate the visitors into installing them.

4.1.2 Where did this come from?

- As per the above, multiple entry points are possible. As all data were destroyed and servers reformatted there were no trace left of the initial breach. With MalwareBytes EPR (Endpoint Protection and Response) deployed, we will be able to track entry points into the environment. Our internal investigations found some IP addresses leading to Lebanon (this is now a matter left to the police with the case we have opened).
- As we restored many servers from un-damaged backups, these will overwrite any information that would have been left on damaged, compromised servers. These servers were immediately either isolated or installed with new AV software.
- Initial reports showed passwords trying to be brute force attacked on the domain controllers on 22 September 2019.

- These hackers clear all login prior to the date of encryption on the servers we have analysed.
- Investigation has shown that RDP (Remote Desktop Services), a service/application used to remotely administer a Microsoft Server, as being the main entry point into the networks. As this is seen as a convenient support tool for clients to manage their own environments these were removed. Where a client insisted of having RDP enabled to his environment the server was moved off the Sautech Network Completely and plugged into the Internet Directly out of the Sautech Hosted environment.
- As we host file services for clients, these are moved off network as distribution is also by files masking to be valid PowerPoint, excel and word documents. Unsuspecting clients may try to open these documents.
- Network Scanning software traces found left no clue where the encryption keys were being send to. These are all standard software not picked up by Anti-Virus Software. Internal investigation show that this could have been used as a “hopping” machine where other scans on the network were conducted. As these are all applications that is downloadable from the internet, Anti-Virus detects no virus in the file which is normal behaviours, with our EPR Solution, we will be alerted with suspicious software scanned on machines.

5 SAUTECH INITIAL ACTIONS

- Sautech (Pty) Ltd responded to the alerts and incidents within minutes and immediately had our internal engineers on site at both our Primary and Disaster Recovery (DR) Data Centres for investigation.
- The ransomware was so sophisticated that it encrypted all servers, destroyed data and deleted backups all within an estimated 15-minute time frame.
- Following the initial investigation, emergency plans were put in place and external providers and experts (Namely, Fast Data Recovery, Synology, Microsoft, Hosting Controller, Stellar Phoenix Data Recovery, Exclaimer, MalwareBytes, Synology and Veeam (All being International Partners)) were contacted in order to assist our engineers with analysing the extent of the damage, recovery plans and assistance in all hosting matters.
- The incident was reported to the SAPS on 01 October 2019.
- **We doubled** our support staff to assist our clients in recovering, setting up profiles, importing and attaching PST files etc.
- Sautech (Pty) Ltd did not pay the ransom but rather took remedial actions straightaway.
- We were advised by our partners and by other businesses with the same type of attack, all of them not successful, not to indulge the hackers. However, initially this option was explored. Research has shown that companies paying the ransom never hear from the attackers again.

6 FLOW OF RECOVERY

6.1.1 Servers / Virtual Servers

- **Our initial timeframe to have 80% of the servers decrypted was 10 business days. Our engineers together with the external providers managed to recover 95% of our servers within 4 business days of the occurrence. 100% of all virtual and physical Servers were recovered within 8 business days.**
- Some clients were recovered within **12 hours** of the incident as we received the initial decryptions from our suppliers and partners.

6.1.2 Email Services

- **Within two business days**, Mail was being delivered to a new exchange Server with outlook web access enabled as a recommendation not to revive the old exchange server. This server has damaged files and the risk of a failure was too great to ignore. Although this is not the optimal solution, this decision with consultation was taken to get our clients to continue working in the interim.
- The decision to commission a new exchange server was not taken lightly and not without consultation from Microsoft support services. We knew what this meant for our clients, but to have mail delivered and business continuing (new email) was a priority for us.
- Clients were initially advised to view emails online via access to webmail exchange, whilst Sautech (Pty) Ltd were in the process of examining backups, damaged files and the decommissioned old exchange servers. Profiles were setup and PST files of OST files on the machines were attached.
- New Exchange Server is running, the amount of email being imported cause some delays and current connectivity issues which will reduce as the imports complete
- **New servers deployed with enterprise solid state drives**
- **Internet speed at Datacentre increased 10X**
- It has been confirmed that some data on the old email environment has been damaged or deleted beyond repair, particularly within the exchange 2016 Data stores. Our offsite monthly backups on 1 August 2019 restored successfully so all email up and till this date we have recovered. Additional email received after this backup date, we also have a copy off in our archive mail stores busy being indexed, the ETA for this indexing is 30 November 2019.

6.1.3 Shared File Services

As reported by our providers that some data is beyond repair. Backups and primary data were either deleted or destroyed. Sadly, some of these documents on our shared file services infrastructure cannot be retrieved. We have had multiple providers scanning and assisting for days to assist us.

7 CHANGES TO THE ENVIRONMENT

- Sautech has implemented Malwarebytes EPR to all production servers within the datacentre.
- Together with Kaspersky anti-virus, these services will run together.
- All Risks servers/services were moved externally to the environment, directly connected on the Internet and not within the Sautech virtual environment.
- Firewall host Servers were changed from Microsoft to VMware.
- CyberArms Intrusion detection deployed to physical servers.
- VLANs (Virtual LANS) were re-created and segregated between clients and customers.
- All physical Hyper-V servers were formatted and reinstalled with Windows 2016 Server Hyper-V.
- We are staying on Checkpoint Firewall Services within all our hosted environments as they proved to be the best.
- Internal WSUS (Window Services Update Services) deployed. This will reduce internal traffic and collect valid authorised updated services for Windows updates.
- All legacy user accounts were again verified and or removed.
- All Systems, hardware and Windows Passwords changed to Sautech Environments
- Dual Switch outbound connectivity installed by Internet Solutions.
- Infected/encrypted NAS machines removed and replaced.
- Weekly backups to be taken to different NAS devices and switched off once backup completes.
- All Hyper-V Servers were taken off domain and replication between one another happens over HTTPS.
- All passwords for clients within the environment (Servers) will increase to minimum 10 characters and busy being implemented.

8 FOLLOW UP/ONGOING ACTIONS

- Partnership signed with FireEye (An American based Cyber Security experts and Solution provider) which is busy testing software with our engineers.
- New Offsite archiving of email being tested with ArcTitan. ArcTitan is a Europe based Email security cloud hosting provider that specialises in Archiving of email and Spam detection.
- Veeam Cloud Connect being tested for Config and Data file backups to a 4th offsite location. ETA for implementation is 1 December 2019
- Secondary Hyper-V replication to be configured over HTTPS, ETA 31 October 2019.
- Multiple other providers are also demoing software at the moment, as decisions are made, these will be communicated.
- As our engineers are in the process of updating their penetration testing (just final International exams left) once completed, we will perform the penetration testing. (Before year end).

9 PREVENTION / TRAINING

There is no known 100% prevention software, tactic or security device in place to prevent such an attack from happening or reoccurring, however, these are known guidelines.

However, most infections and ransomware can be avoided, stopped by educating the users on basic strategies etc.

Ransomware attacks are all too common these days. Major companies in North America and Europe alike have fallen victim to it. Cybercriminals will attack any consumer or any business and victims come from all industries.

Several government agencies, including the FBI, advise against paying the ransom to keep from encouraging the ransomware cycle. Furthermore, half of the victims who pay the ransom are likely to suffer from repeat attacks.

- If you are unsure of an email original or content, do not open it.
- Make sure your desktops/laptops and servers are up to date with OS updates, you have a reputable anti-virus software on your machine.
- Never download or install cracked/patches software on any device.
- If you have opened an attachment or clicked on a link that you think may be suspicious, rather inform your IT support staff or service provider immediately.
- Don't use the same password across all your login accounts.
- Change password regularly and use a combination of upper, lower, symbol and numbered characters.

Sautech will start with a series of emails and educational emails to our clients or anyone interested in device security, password protection etc. should you wish to signup, please send an email to subscriptions@sautech.net

10 CONCLUSION

- On the 30th of September 2019, Fast Data Recovery in Australia (Being World leaders in Ransomware Encryption) confirmed that NO data was breached, copy of Report attached hereto.
- Initial Hacker correspondence attached for reference.
- Sautech (Pty) Ltd. Reserves all its rights in this report.
- As new information is found, it will be circulated.

11 THANK YOU

- Thank you to you, our clients, I know this has been extremely difficult for both of us, thank you for standing by us.
- Our partners, locally and internationally that assisted with this crisis. Special Thanks to the Australian Firm, Data Recovery Experts that worked 24/7 assisting us.
- Hosting Controller in Canada for their amazing support and continued assistance.
- Stellar Phoenix writing special software to assist with the email import process.
- Checkpoint Firewall for never letting us down.
- Internet Solution for increasing our internet speed by 10x.
- Malwarebytes deploying EPR Malware Detection to our Servers .
- Finally, our Staff, working around the clock and continuing to build and improve.



Riaan van Jaarsveld
Director

2019/10/17